

Lesson 2

Introduction to enumeration and vulnerability discovery and tools

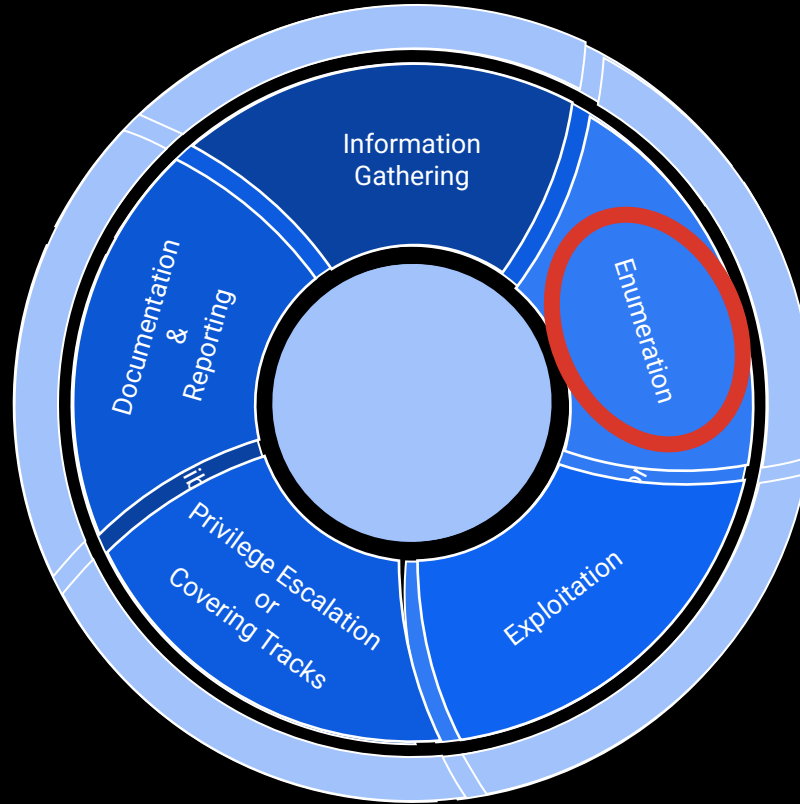
Disclaimer

What you will go through in this course, is highly highly niched skills that can make you a highly valuable asset in an organization, or an overnight criminal when things are done without permission, or the right ethical considerations.

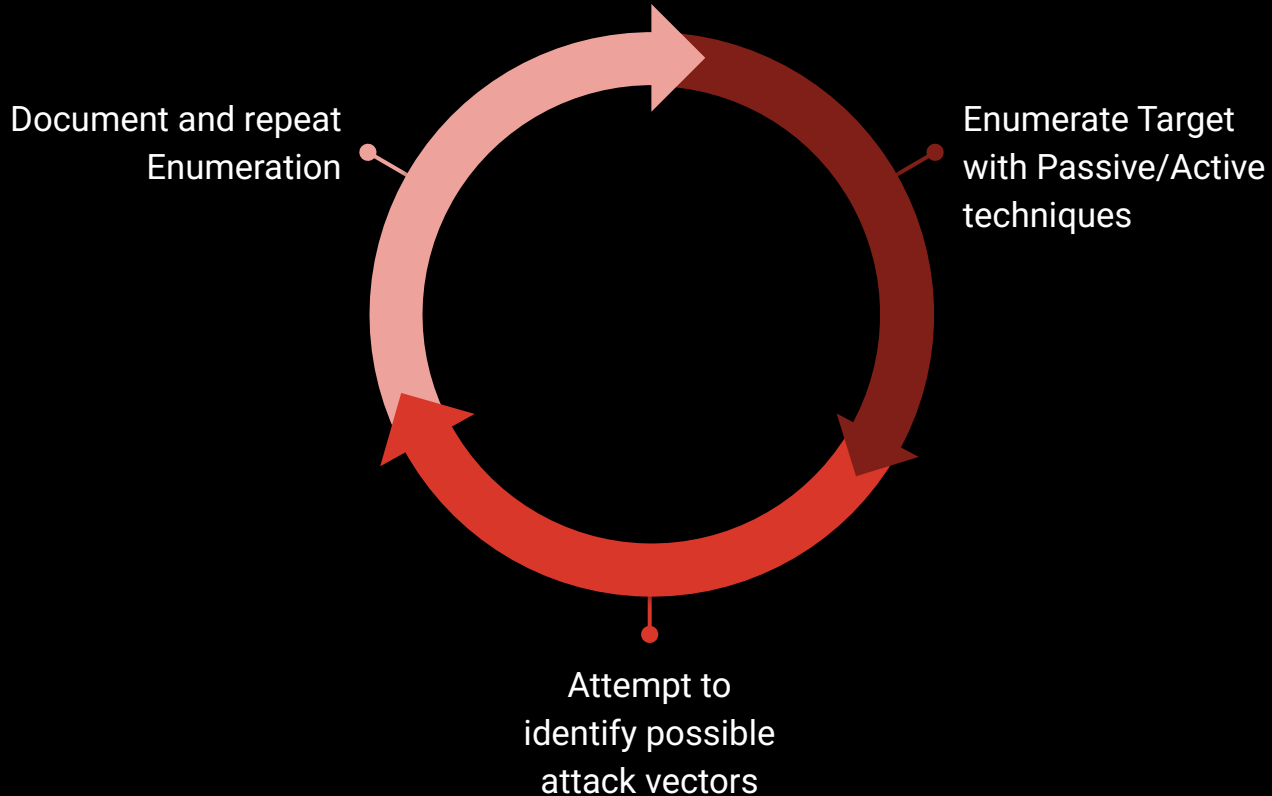
You CAN land in trouble if you breach the computer misuse act, and in no capacity I will be vouching for you, sanctioning you, or even allowing you to attack on properties that are not own by me, or for lesson purpose.

So please, help me to help you by not doing anything taught in class, onto someone else.

Penetration Testing Life Cycle



The Enumeration Cycle



Enumeration

There are mainly two types of Enumeration:

- Passive Enumeration
- Active Enumeration
 - Authenticated
 - Unauthenticated

Passive Enumeration

It is often similar to Passive Information Gathering

Your goal here is different. You want to identify technical information that is of tactical importance. (How does it affect your exploitation)

Low-risk, indirect discovery using third-party/public data

Passive Actions

DNS zone transfers - (if misconfigured)

SSL certificate inspection

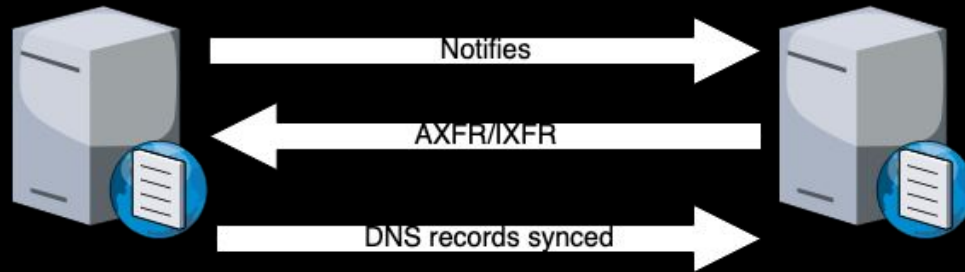
Publicly leaked credential dumps - GitHub/GitLab

Open source tools (dnsdumpster, crt.sh, sub-domain enumeration)

DNS zone transfers - (if misconfigured)

Attempt to zone transfer from a domain name server so as to achieve additional domain information. This also means domain records that could be “not public”

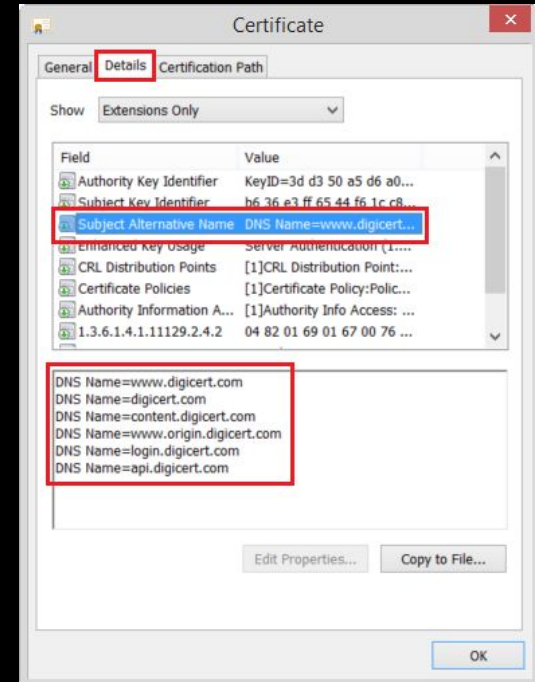
`dig axfr example.com @Name.Server.IP`



SSL certificate inspection

You can look at a SSL cert of a website to find out what other Domain it has!

Because each SSL Cert needs to match the CN (Common Name) or SAN (Subject Alternative Name) to prevent Certificate Errors.



Publicly leaked credential dumps - GitHub/GitLab

With vibe-coding and “get quick to coding” schemes becoming a norm, best practices are often not followed to favour product delivery

This means you can search for potentially “mis-commited” credentials in GitHub/GitLab

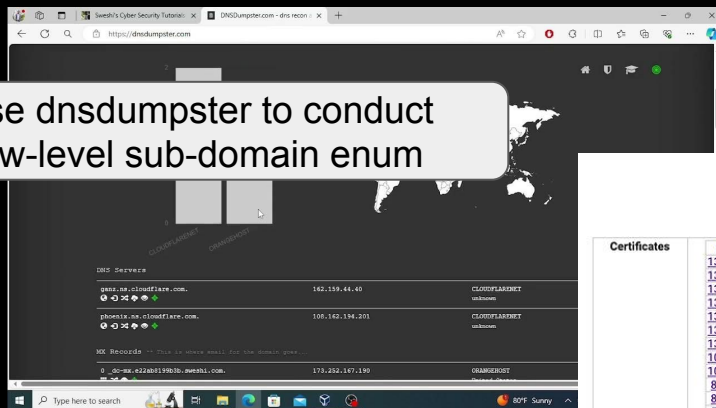
<https://developer.cyberark.com/blog/how-to-scan-github-repositories-for-secrets-credentials-with-open-source/>

Open source tools (dnsdumpster, crt.sh, sub-domain enumeration)

Much can be discovered through third-party enumeration tool.

DNSDumpster

Use dnsdumpster to conduct low-level sub-domain enum



CRT.SH

Any sub-domain enumeration tool

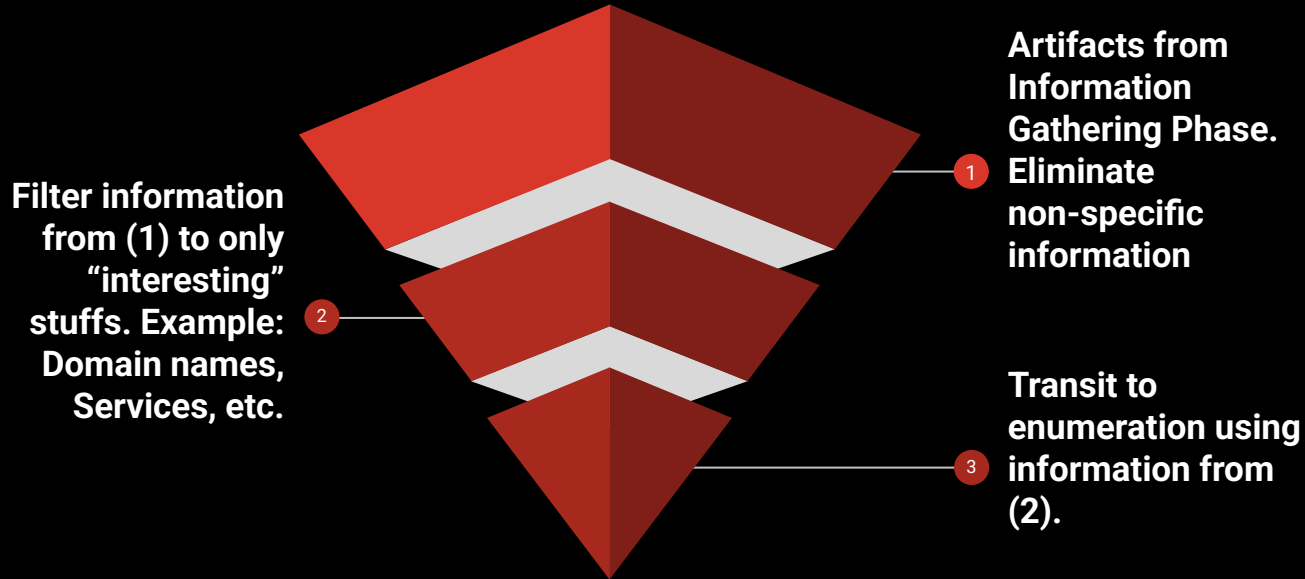
Use crt.sh to conduct certificate enumeration

A screenshot of the crt.sh Identity Search interface. The search criteria is set to 'Identity = "dinapolilevels.com"'. The results are displayed in a table with columns: 'Certificates', 'crt.sh ID', 'Logged At', 'Not Before', 'Not After', and 'Issuer Name'. The table lists 15 certificates, all issued by 'C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3'. The 'Logged At' dates range from 2018-02-28 to 2019-04-07. The 'Not Before' and 'Not After' dates also range from 2018-02-28 to 2019-04-07.

Certificates	crt.sh ID	Logged At	Not Before	Not After	Issuer Name
	1361079872	2019-04-07	2019-04-07	2019-07-06	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1361081062	2019-04-07	2019-04-07	2019-07-06	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1361076376	2019-04-07	2019-04-07	2019-07-06	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1361076351	2019-04-07	2019-04-07	2019-07-06	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1361075073	2019-04-07	2019-04-07	2019-07-06	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1357296814	2019-04-04	2019-07-03	2019-07-03	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1348729674	2019-04-04	2019-04-04	2019-07-03	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1082078081	2019-01-05	2019-01-05	2019-04-05	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	1082070348	2019-01-05	2019-01-05	2019-04-05	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	829826313	2018-10-06	2018-10-06	2019-01-04	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	829825919	2018-10-06	2018-10-06	2019-01-04	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	595168726	2018-07-09	2018-07-09	2018-10-07	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	589043435	2018-07-09	2018-07-09	2018-10-07	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	391170347	2018-04-10	2018-04-10	2018-07-09	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	389282331	2018-04-10	2018-04-10	2018-07-09	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
	343626127	2018-02-28	2018-02-28	2018-05-29	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3

Why do Passive Enumeration?

In the transition from Information Gathering to Enumeration, your enrichment of information requires additional steps that allows you to scope your targets.



Active Enumeration

Now you have reached the fun part!

You would typically be looking for:

Network Services

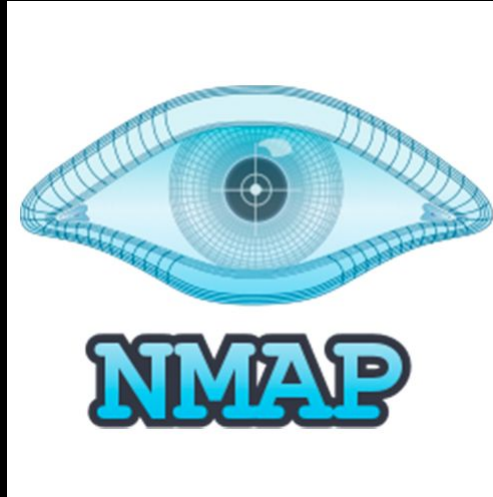
Web Services

You can either be **Authenticated** or **Unauthenticated**

Network Enumeration

Every penetration tester will use the tool called NMAP (Network Mapper)

*Disclaimer: The form of scanning is an act of offensive security action. Only conduct scanner where permitted. In certain countries, scanning without permission is illegal.



Why Use Nmap for Enumeration?

Identify which hosts are alive on a network (Host discovery)

Discover open ports and associated services

Detect service versions and operating systems

Spot potential vulnerabilities or misconfigurations

Lay the groundwork for further exploitation or analysis

Basic Host Discovery

Command:

`nmap 192.168.1.1` (Checks if the host is up and lists open ports)

*Uses ICMP, TCP SYN, or ARP (depending on options and privilege of user running the tool)

Range and Subnet Examples:

`nmap 192.168.1.0/24`

`nmap 10.0.0.1-50`

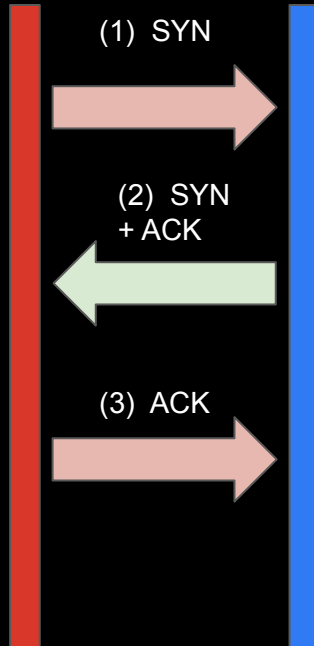
Common Scan Types

Scan Type	Flag	Description
TCP SYN (Stealth)	-sS	Sends SYN packets, fast and less noisy
TCP Connect	-sT	Uses full TCP handshake
UDP Scan	-sU	Scans for UDP services
Ping Scan	-sn	Host discovery only, no ports
Version Detection	-sV	Attempts to detect service versions
OS Detection	-O	Attempts to detect operating system

SYN scan

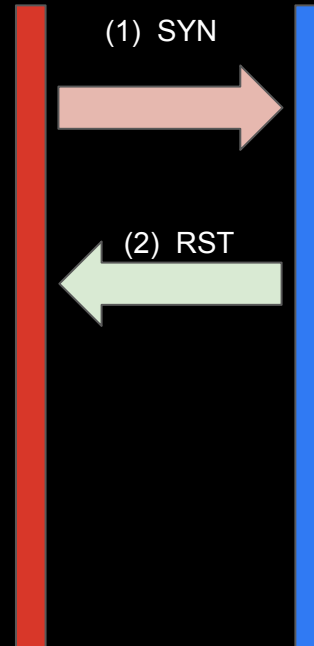
PORT OPEN

Attacker Target



PORT CLOSED

Attacker Target



Detail Scan Types

Scan Type	Flag	Description	Stealthy?	Requires Root?
TCP SYN Scan	-sS	Sends SYN, waits for SYN-ACK. Doesn't complete the TCP handshake.	Yes	Yes
TCP Connect Scan	-sT	Uses full TCP handshake. Default when not running as root.	No	No
UDP Scan	-sU	Sends UDP packets to target ports. Slow but useful for enumerating UDP.	Somewhat	Yes
TCP Null Scan	-sN	Sends TCP packets with no flags set. Relies on RFC-compliant responses.	Yes	Yes
TCP FIN Scan	-sF	Sends TCP packets with the FIN flag.	Yes	Yes
TCP Xmas Scan	-sX	Sends TCP packets with FIN, URG, and PSH flags (like a lit-up tree).	Yes	Yes
TCP ACK Scan	-sA	Sends ACK packets. Used to map firewall rules, not port states.	Yes	Yes

Port Scanning in Action

Scan specific ports:

```
nmap -p 22,80,443 192.168.1.10
```

Scan all 65,535 TCP ports:

```
nmap -p- 192.168.1.10
```

Scan the top 100 most commonly used ports:

```
nmap --top-ports 100 192.168.1.10
```

In our curriculum, we denote “standard ports” as ports from 0-1023

“Non standard ports” are 1024 - 65535

Service Version and OS Detection

```
nmap -sV -O 192.168.1.10
```

-sV: Tries to determine software/service versions

-O: Performs OS fingerprinting

Helpful for identifying outdated services or vulnerable operating systems

Aggressive Scan

```
nmap -A 192.168.1.10
```

Combines multiple options: OS detection, version detection, script scanning, and traceroute

Good for deep enumeration but can be loud (easily detected)

Should not be used on sensitive systems, may cause it to crash

Output Formats

```
nmap -oN output.txt 192.168.1.10 # Normal output
```

```
nmap -oX output.xml 192.168.1.10 # XML format
```

```
nmap -oG output.gnmap 192.168.1.10 # Grepable format
```

Useful for saving results, automation, or feeding into other tools.

You can take outputs like this, throw it into OpenAI

NSE Scripts

```
nmap --script vuln 192.168.1.10
```

Nmap Scripting Engine (NSE) allows advanced scans

The vuln category runs vulnerability detection scripts

Other categories include auth, default, safe, exploit, discovery, etc.

<https://nmap.org/nsedoc/categories/vuln.html>

More Scan Examples

```
nmap -sS -p 22,80,443 -T4 192.168.1.10
```

```
nmap -A --script=default,vuln -T4 192.168.1.10
```

```
nmap -sU -T4 192.168.1.10 [Adjust -T timing: 0 (Paranoid) to 5 (Insane)]
```

Always use modifiers wisely. It can be VERY VERY intrusive.

NMAP recommended practices

Always define scope and get authorization before executing Scans

Use -T4 for faster scans, but be mindful of IDS detection (so avoid this if you want to avoid detection)

Avoid aggressive scans on production systems unless permitted

Use NSE scripts to enhance findings

Save output for later reference or reporting

Remember to look at UDP ports as well

Alternatives

You can use the following commands to do similar actions of enumeration:

telnet 192.168.1.1 25 (This initiates a connection with telnet client port 25, and it also grabs the banner of the service)

nc 192.168.1.1 25 (This initiates a connection using the NetCat or ncat client on port 25)

SMB enumeration

SMB / SAMBA is a file share service on port 445.

It is common associated with: Windows Share/Linux Share

You can use **enum4linux** to enumerate this service to get more info, such as share names, share permissions, local users on the machine, and machine information

```
enum4linux -a 192.168.1.10
```

SMBClient

You can use smbclient to list shares using the -N flag to list shares without authentication

```
smbclient -L //192.168.1.10/ -N
```

CME (CrackMapExec)

You can use crackmapexec command to enumerate SMB with a given CIDR.

```
crackmapexec smb 192.168.1.0/24
```

Other form of enumeration

Command	Example	Purpose	Use Case
snmpwalk	snmpwalk -v2c -c public 192.168.1.10	192.168.1.10 Dumps SNMP data like system name, uptime, interfaces using the public community string. "v2c" is the verison of SNMP	SNMP
ldapsearch	ldapsearch -x -h 192.168.1.10 -b "dc=corp,dc=local"	Queries LDAP for users, groups, OUs	LDAP
gobuster	gobuster dir -u http://example.com -w /usr/share/wordlists/dirb/common.txt	Bruteforces directories and files on a given webpage	Web Service
nikto	nikto -h http://example.com	Searches for common web vulnearbilities	Web Service

Web Service Enumeration

In Web Service Enumeration, we take note of the:

Headers

IP Address it used

External libraries/services it loads

Is it a Single Page Application, monolithic app, or multi-page web app

Is it done in ReactJS, VueJS, NuxtJS etc

Is it using web sockets?

Web Service Enumeration

Headers

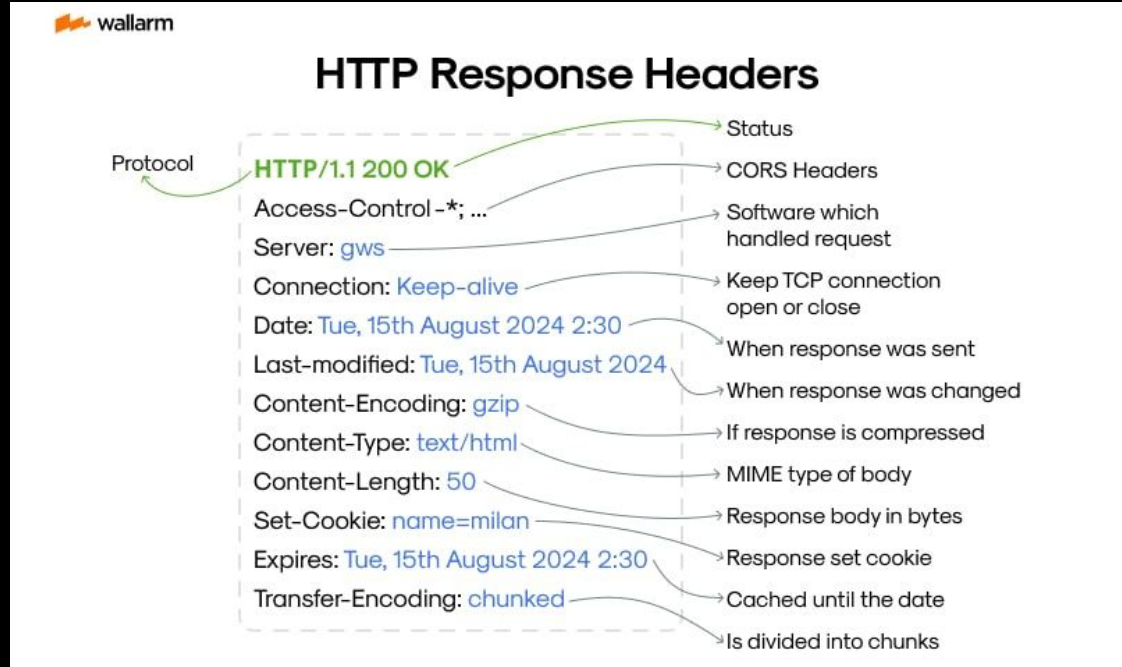
IP Address it used

External libraries/services it loads

Is it a Single Page Application, monolithic app, or multi-page web app

Is it done in ReactJS, VueJS, NuxtJS etc

Is it using web sockets?



Web Service Enumeration

Headers

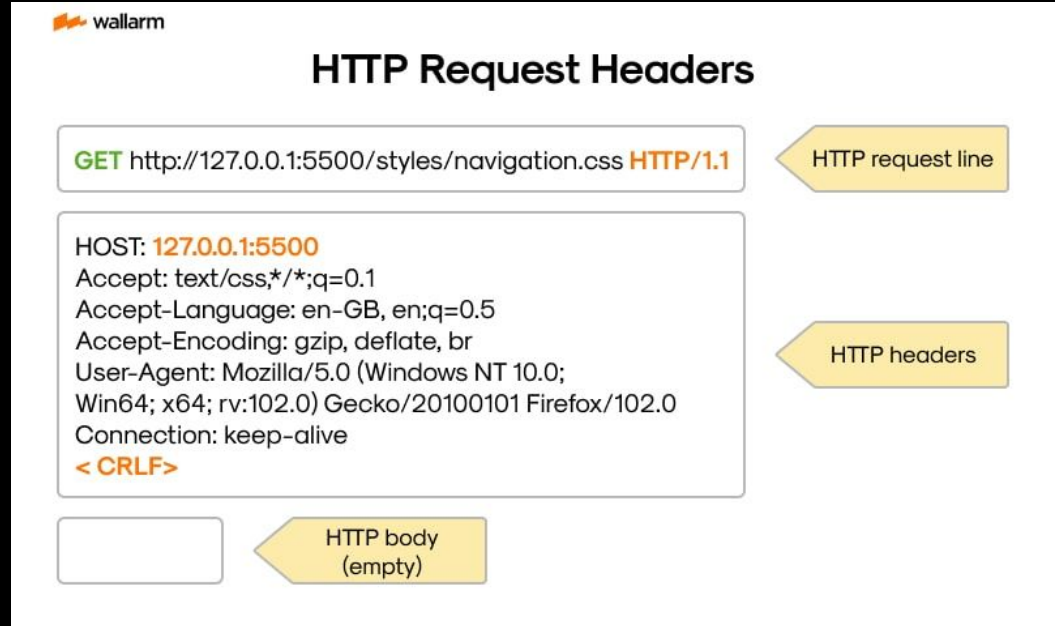
IP Address it used

External libraries/services it loads

Is it a Single Page Application,
monolithic app, or multi-page web
app

Is it done in ReactJS, VueJS,
NuxtJS etc

Is it using web sockets?



Web Service Enumeration

Headers

IP Address it used

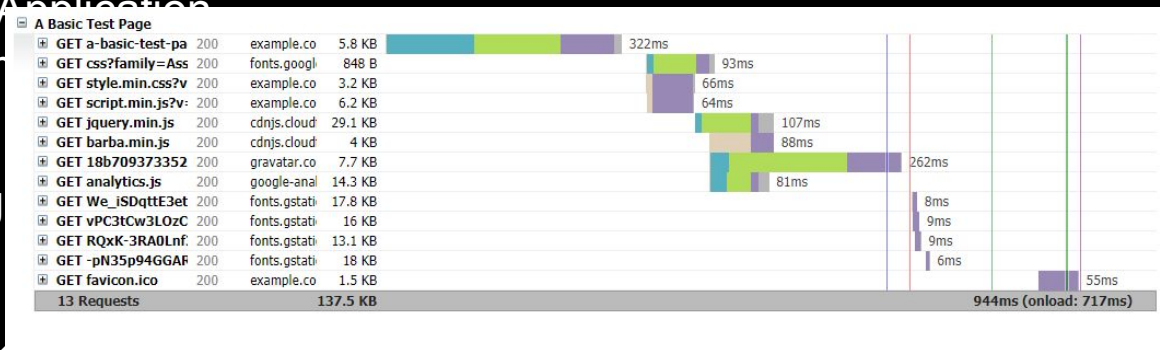
External libraries/services it loads

Is it a Single Page Application

monolithic app, or micro
app

Is it done in ReactJS
NuxtJS etc

Is it using web sockets?



Web Service Enumeration

Headers

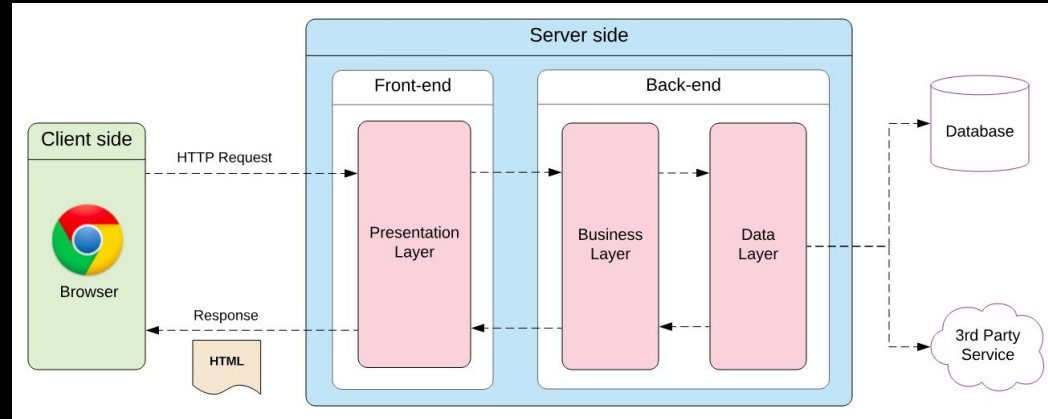
IP Address it used

External libraries/services it loads

Is it a Single Page Application, monolithic app, or multi-page web app

Is it done in ReactJS, VueJS, NuxtJS etc

Is it using web sockets?



Web Service Enumeration

Headers

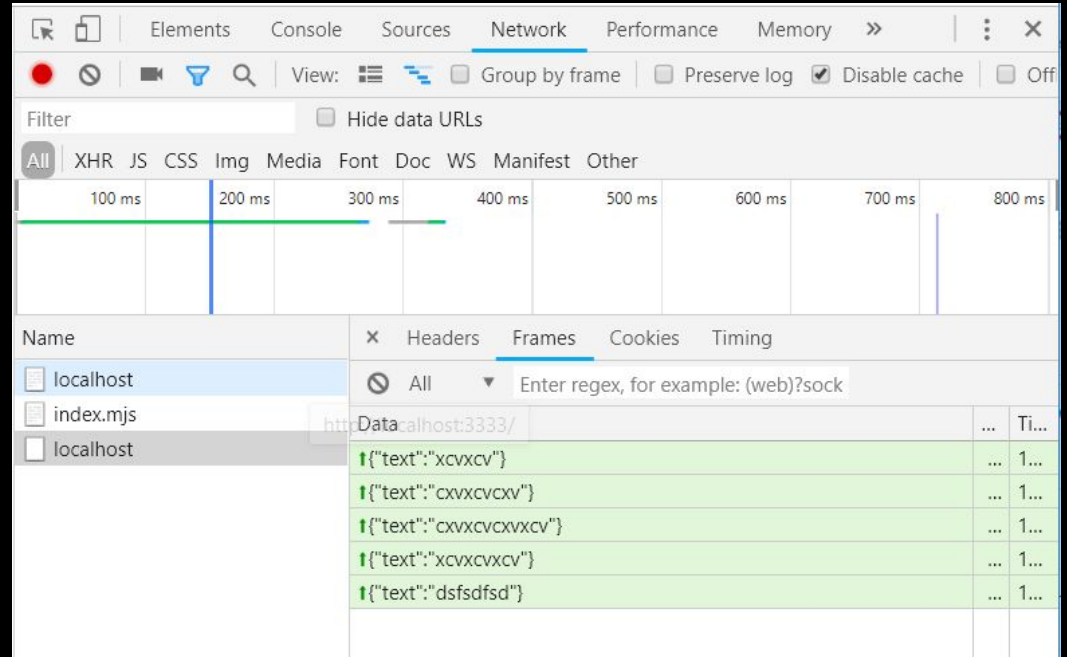
IP Address it used

External libraries/services it loads

Is it a Single Page Application, monolithic app, or multi-page web app

Is it done in ReactJS, VueJS, NuxtJS etc

Is it using web sockets?



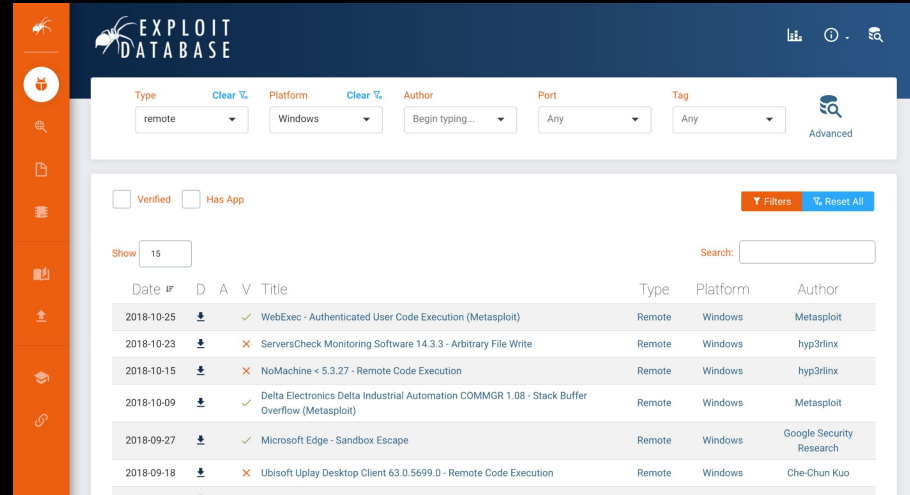
What do you want to look for in ALL types of enumeration?

Service Version Number - Key this into google and search for potential existing exploits

Outdated Systems/Misconfigurations that are documented and can be exploited

You leave NO service un-visted until you found something you can “possibly” exploit.

www.exploit-db.com



The screenshot shows the Exploit Database interface. The top navigation bar includes the logo and search icons. Below it, there are filters for Type (remote), Platform (Windows), Author (Begin typing...), Port (Any), and Tag (Any). There are also checkboxes for Verified and Has App, and buttons for Filters and Reset All. A search bar is present on the right. The main content area displays a table of exploits with columns for Date, ID, D, A, V, Title, Type, Platform, and Author. The table lists several exploits, including WebExec - Authenticated User Code Execution (Metasploit), ServersCheck Monitoring Software 14.3.3 - Arbitrary File Write, NoMachine < 5.3.27 - Remote Code Execution, Delta Electronics Delta Industrial Automation COMMGR 1.08 - Stack Buffer Overflow (Metasploit), Microsoft Edge - Sandbox Escape, and Ubisoft Uplay Desktop Client 63.0.5699.0 - Remote Code Execution.

Date	ID	D	A	V	Title	Type	Platform	Author
2018-10-25					WebExec - Authenticated User Code Execution (Metasploit)	Remote	Windows	Metasploit
2018-10-23					ServersCheck Monitoring Software 14.3.3 - Arbitrary File Write	Remote	Windows	hyp3rlinx
2018-10-15					NoMachine < 5.3.27 - Remote Code Execution	Remote	Windows	hyp3rlinx
2018-10-09					Delta Electronics Delta Industrial Automation COMMGR 1.08 - Stack Buffer Overflow (Metasploit)	Remote	Windows	Metasploit
2018-09-27					Microsoft Edge - Sandbox Escape	Remote	Windows	Google Security Research
2018-09-18					Ubisoft Uplay Desktop Client 63.0.5699.0 - Remote Code Execution	Remote	Windows	Che-Chun Kuo

Use what you have found during enumeration, match the CVE/Exploit name, and find the exploit online!

Exploit Not Found?

No exploit found does not mean it is not vulnerable.

Maybe the way to exploit it is to do it by hand? :)

Sometimes, you have to understand why the system is vulnerable.

Enumeration gives you sufficient information to form questions

Always doubt yourself, and look for more options to find a loophole, not tunnel vision-ed to one.

What in the current service I am investigating can break, when given a user supplied input

What is the likely permission it has, and what type of dependencies does it likely depend on?

Is it a custom service, or a well known and maintained open source service, or vendor specific.

Enumeration is not the end, it is never the end

Whenever you enumerate, you gain new information

You do not stop there and “tunnel vision”. Always try both **authenticated** and **unauthenticated**. Look for new ways to gather information with Authentication.

Continue to enumeration, gather as much information as you can. (Revisit tools with creds)



Enumeration is Hard. Real Hard.

The hardest, most time consuming, and mental stressing part of the entire penetration test cycle.

You either find something, or you find nothing.

However, this also means you need to learn on the go, when encountered with new technologies, never back down. Just ask yourself...

“How can this system break?”

“What does it depend on?”

“What is the current security models and assumptions?”

“Can I do X or Y differently?”

Typical workflow

1. Host discovery of the network
2. You proceed to NMAP a network
3. You determine possible attack vectors, and you proceed to test it
4. You realize there is an unauthenticated network drive, you access the share drive and found credentials
5. You use those credentials again to do enum4linux with the credentials, and found even more information (previously not found without credentials)
6. You found a share called “secret_drive” and you access it, found SSH credentials to a server
7. <<Here onwards, its exploitation onwards>>

Use NMAP to do host discovery



Use python to discover hosts then NMAP scan



Writing a Python Script to do TCP handshake scans



Re-writing NMAP in Go for multi threading and running it



Write your own scanner in C++ and ask OpenAI to run it



Break Time

Hands On Exercise (Assignment 2)

1. What are the sub-domains for grab.com?
2. What are the sub-domains for smu.edu.sg?
3. What services are available in 174.138.22.246?
4. What port(s) were opened that are non-standard?
5. Which port gave you a flag, and what is the value?

Include screenshots

Please document your findings and submit on elearn